

2017-07-22 TRAFFIC ANALYSIS EXERCISE - ANSWERS

YOUR TASK:

One of the hosts in the exercise pcap had something bad happen to it. Your task? Figure out which host it was, and determine what might have happened.

ANSWER:

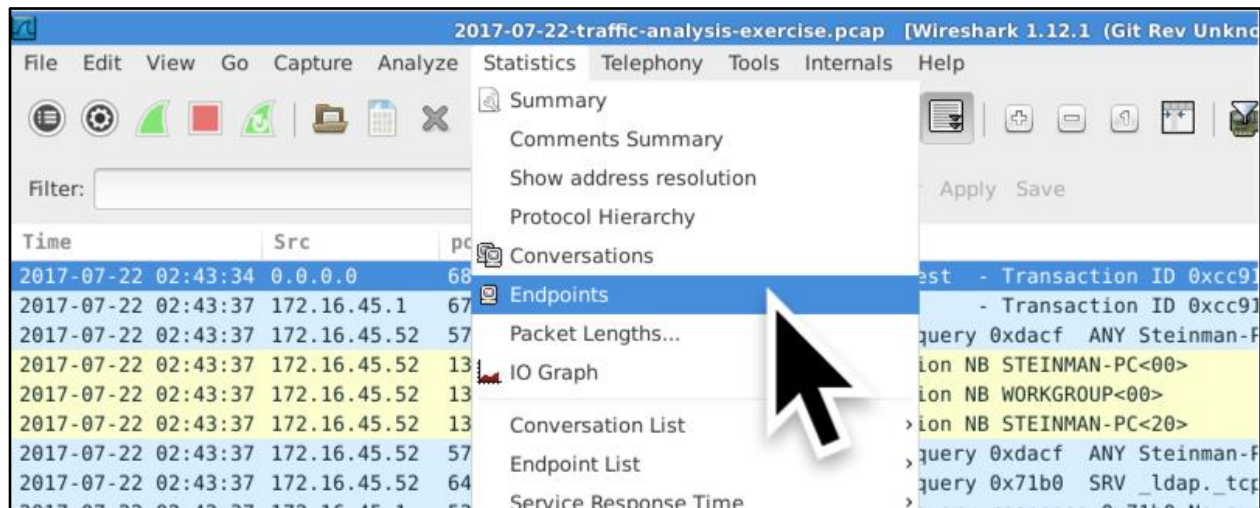
Windows host Mean-Gene-PC at 172.16.45.98 (MAC address 00:18:f3:0e:f3:fa), has been infected with malware, probably a Zyklon HTTP bot as described [here](#).

HINTS:

As always, I recommend you set up Wireshark in accordance with my guide at:

- <http://www.malware-traffic-analysis.net/tutorials/wireshark/index.html>

First, the pcap has more than one host in it, so you'll have to figure out what these hosts are. Let's look at Endpoints under the Statistics menu:



Sort the Ethernet addresses according to Bytes, and you'll see three that are interesting.

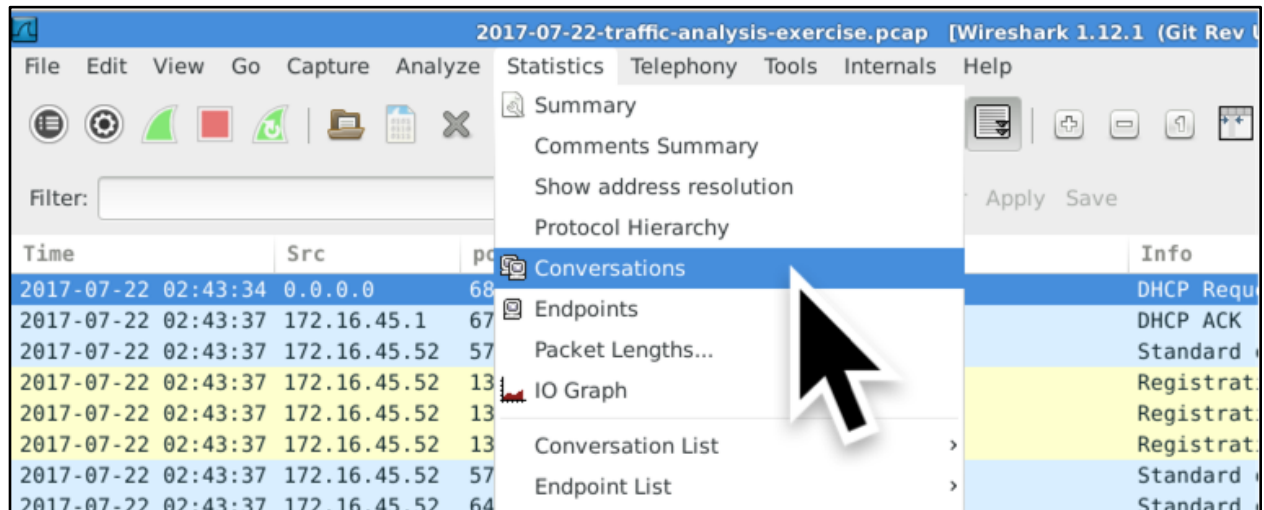
A screenshot of the 'Endpoints: 2017-07-22-traffic-analysis-exercise.pcap' window. The 'Ethernet: 7' tab is selected, and the 'Bytes' column is sorted in descending order. A red box highlights the top three entries: 08:ec:a9:75:be:14, AsustekC_0e:f3:3a, and Dell_c3:1b:e9. A large black arrow points to the 'Bytes' column header.

Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes
IPv4mcast_fc	26	1 814	0	0	26	1 814
Broadcast	53	9 638	0	0	53	9 638
IPv4mcast_7f:ff:fa	30	15 573	0	0	30	15 573
08:ec:a9:75:be:14	1 889	1 067 195	930	128 589	959	938 606
AsustekC_0e:f3:3a	2 222	1 854 133	802	65 545	1 420	1 788 588
Dell_c3:1b:e9	21 402	15 291 639	9 767	994 566	11 635	14 297 073
Cisco_01:e9:5c	25 488	18 225 404	14 056	17 043 998	11 432	1 181 406

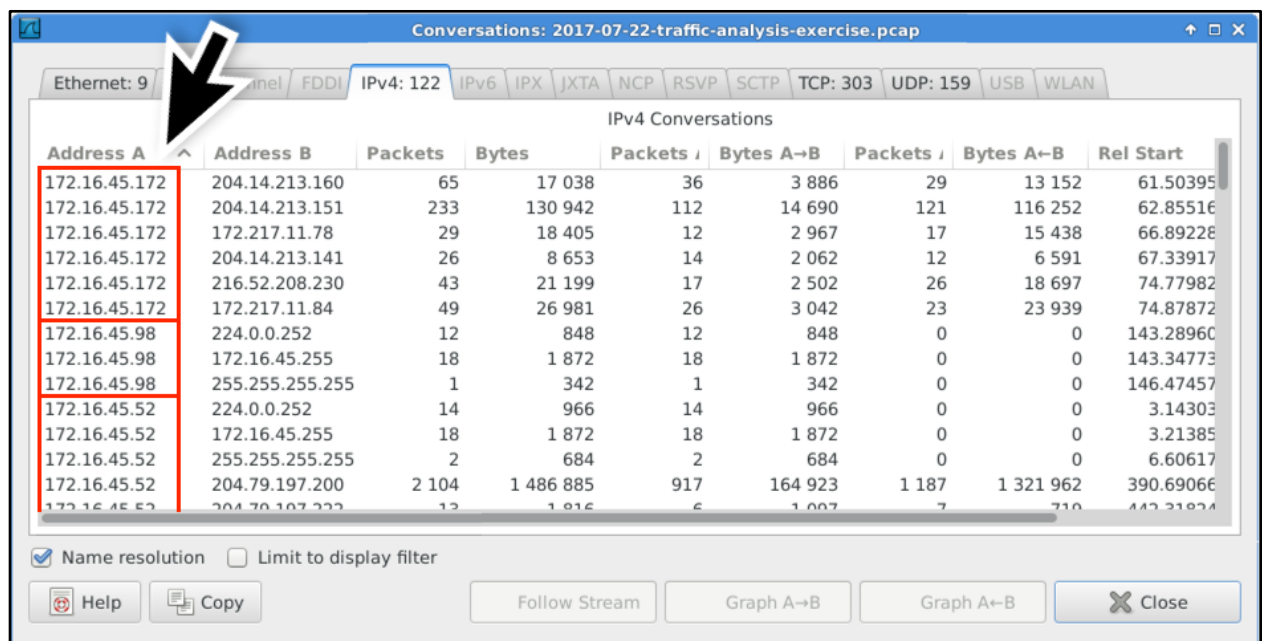
2017-07-22 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Skip the IPv4mcast and Broadcast addresses, and you're left with 4 Ethernet addresses. One of these is the router for the network, which is the one named Cisco. That leaves 3 Ethernet addresses: one identified as Dell, one identified as Asus, and one without any identification.

Let's now look at Conversations under the Statistics menu:



By sorting through, you'll find the non-routable IP addresses used by the 3 hosts. They'll either be class A (10.0.0.0/8) class B (172.16.0.0/12) or class C (192.168.0.0/16).



But which host is associated with bad activity? If you submit the exercise pcap to [VirusTotal](#), you'll find some Snort and Suricata alerts for clues. In fact, the pcap has already been submitted, which you can see [here](#).

2017-07-22 TRAFFIC ANALYSIS EXERCISE - ANSWERS



SHA256: 43f87c33d074b95d4b7b1dec96eea07172e39771790200e76e2a97b5d1e8c45f

File name: 2017-07-22-traffic-analysis-exercise.pcap

Detection ratio: 0 / 57

Analysis date: 2017-07-22 04:02:04 UTC (10 hours, 47 minutes ago)



Analysis

File detail

Additional information

Comments 0

Votes

Intrusion Detection System	Result
Snort	27 alerts
Suricata	13 alerts

Antivirus	Result	Update
Ad-Aware	✓	20170722
AegisLab	✓	20170722

If you review the alerts, you'll find ETPRO hits on MSIL/Zyklon malware. Unfortunately, it doesn't show which IP address triggered the alerts, nor can we see what traffic those alerts triggered on. At this point, all we know is those alerts triggered on traffic within the pcap.

Suricata alerts Emerging Threats ETPRO ruleset

ET POLICY Unallocated IP Space Traffic - Bogon Nets (Potentially Bad Traffic) [2002749]

ET DOS Cisco Router HTTP DoS (Attempted Denial of Service) [2000006]

ETPRO TROJAN Common Downloader Header Pattern H (Unknown Traffic) [2803305]

ETPRO TROJAN MSIL/Zyklon/Censer Plugin DL (A Network Trojan was Detected) [2820512]

ET POLICY Reserved Internal IP Traffic (Potentially Bad Traffic) [2002752]

ETPRO CURRENT_EVENTS Possible Nuclear EK Payload (URI Primer) Apr 04 (A Network Trojan was Detected) [2816896]

ET TROJAN Trojan Generic - POST To gate.php with no accept headers (A Network Trojan was Detected) [2022985]

ETPRO TROJAN MSIL/Zyklon CnC (getkey) (A Network Trojan was Detected) [2815529]

ET TROJAN Trojan Generic - POST To gate.php with no referer (A Network Trojan was Detected) [2017930]

GPL WEB_CLIENT web bug 0x0 gif attempt (Misc activity) [2102925]

GPL MISC UPnP malformed advertisement (Misc Attack) [2101384]

ET POLICY Possible IP Check myexternalip.com (Potential Corporate Privacy Violation) [2019980]

ETPRO TROJAN MSIL/Zyklon CnC (key) (A Network Trojan was Detected) [2815530]

You can filter traffic on each of the three IP addresses in Wireshark, export those packets into separate pcaps based on the IP, then submit those pcaps to Wireshark. That way, you could figure out which of the three IP addresses were infected.

But maybe we can figure it out based on the HTTP traffic. Let's do some *http.request* filtering and see what we can find.

2017-07-22 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Filter: **http.request and ip.addr eq 172.16.45.52** Expression... Clear Apply Save

Time	Dst	port	Host	Info
2017-07-22 02:43:43	63.217.21.26	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1
2017-07-22 02:50:05	204.79.197.200	80	www.bing.com	GET / HTTP/1.1
2017-07-22 02:50:05	204.79.197.200	80	www.bing.com	GET /s/a/hpc20.png HTTP/1.1
2017-07-22 02:50:05	204.79.197.200	80	www.bing.com	GET /fd/s/a/hp/bing.svg HTTP/1.1
2017-07-22 02:50:05	204.79.197.200	80	www.bing.com	GET /fd/ls/l?IG=22561A2E2A7B499EBD494C90001060576CID=3B34C29A3E1C6F
2017-07-22 02:50:05	204.79.197.200	80	www.bing.com	GET /sa/simg/bing_p_rr_teal_min.ico HTTP/1.1
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	POST /fd/ls/lsp.aspx? HTTP/1.1
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/BingCore.Bundle/cj,nj/266e9574/1d44e273.js?bu=rms+answers+
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/rms%20answers%20Identity%20Blue\$BlueIdentityDropdownBootSt
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/rms%20answers%20Identity%20Blue\$BlueIdentityHeader/cj,nj/0
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/rms%20answers%20Identity%20SnrWindowsLiveConnectBootstrap/
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/rms%20answers%20Rewards%20RewardsNcHeaderBootstrapAjax/cj,
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/rms%20answers%20Rewards%20ReportActivityBootstrap/cj,nj/b0
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	GET /rms/Framework/cj,nj/f0fe13d0/9101d3f2.js?bu=rms+answers+BoxMod
2017-07-22 02:50:06	204.79.197.200	80	www.bing.com	POST /rmwdrconn/rchheader?vers=R A1 A AAAAAATTn=4FRP %A67A76a??%A1A

Frame 47: 151 bytes on wire (1208 bits), 151 bytes captured (1208 bits)
Ethernet II, Src: Dell c3:1b:e9 (00:26:b9:c3:1b:e9), Dst: Cisco 01:e9:5c (00:09:e8:01:e9:5c)
Internet Protocol Version 4, Src: 172.16.45.52 (172.16.45.52), Dst: 63.217.21.26 (63.217.21.26)
Transmission Control Protocol, Src Port: 49157 (49157), Dst Port: 80 (80), Seq: 1, Ack: 1, Len: 97

In the above image, I've filtered on **http.request and ip.addr eq 172.16.45.52** to find a user going to Bing. If you follow some TCP streams and examine the traffic, you'll find a Bing search on "singapore news" followed by traffic to **www.channelnewsasia.com**. I've also matched the MAC address to the IP address in the frame details section.

Filter: **http.request and ip.addr eq 172.16.45.98** Expression... Clear Apply Save

Time	Dst	port	Host	Info
2017-07-22 02:46:03	63.217.21.26	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1
2017-07-22 02:49:28	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1
2017-07-22 02:49:29	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:49:29	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:49:30	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:49:31	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:49:31	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:50:31	104.18.40.172	80	service.tellepizza.com	GET /plugin/index.php?plugin=browser HTTP/1.1
2017-07-22 02:50:31	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:50:32	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur
2017-07-22 02:50:34	104.18.40.172	80	service.tellepizza.com	GET /plugin/index.php?plugin=email HTTP/1.1
2017-07-22 02:50:42	104.18.40.172	80	service.tellepizza.com	GET /plugin/index.php?plugin=software HTTP/1.1
2017-07-22 02:50:43	104.18.40.172	80	service.tellepizza.com	POST /gate.php HTTP/1.1 (application/x-www-form-ur

Frame 1777: 151 bytes on wire (1208 bits), 151 bytes captured (1208 bits)
Ethernet II, Src: Asustek 0e:f3:3a (00:18:f3:0e:f3:3a), Dst: Cisco 01:e9:5c (00:09:e8:01:e9:5c)
Internet Protocol Version 4, Src: 172.16.45.98 (172.16.45.98), Dst: 63.217.21.26 (63.217.21.26)
Transmission Control Protocol, Src Port: 49157 (49157), Dst Port: 80 (80), Seq: 1, Ack: 1, Len: 97

In the above image, I've filtered on **http.request and ip.addr eq 172.16.45.98** to find an IP address check, with server HTTP POST requests (and some GET requests) to **service.tellepizza.com**. I've also matched the MAC address to the IP address in the frame details section.

In the image below, I've filtered on the final IP we found earlier, doing **http.request and ip.addr eq 172.16.45.172** to find HTTP traffic to newegg.com. Note there is a lot of HTTPS traffic to Newegg that doesn't show up with this filtering.

2017-07-22 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Filter: Expression... Clear Apply Save

Time	Dst	port	Host	Info
2017-07-22 02:44:35	23.203.224.60	80	newegg.com	GET / HTTP/1.1
2017-07-22 02:44:36	204.14.213.160	80	www.newegg.com	GET / HTTP/1.1

.....

▶ Frame 67: 534 bytes on wire (4272 bits), 534 bytes captured (4272 bits)

▶ Ethernet II, Src: 08:ec:a9:75:be:14 (08:ec:a9:75:be:14), Dst: Cisco_01:e9:5c (00:09:e8:01:e9:5c)

▶ Internet Protocol Version 4, Src: 172.16.45.172 (172.16.45.172), Dst: 23.203.224.60 (23.203.224.60)

▶ Transmission Control Protocol, Src Port: 40382 (40382), Dst Port: 80 (80), Seq: 1, Ack: 1, Len: 468

If you follow the TCP stream for either of these HTTP requests, the user-agent string in the HTTP headers indicates this is a Samsung Android device.

Filter: tcp.stream eq 1					Expression... Clear Apply Save
Time	Dst	port	Host	Info	
2017-07-22 02:44:35	23.203.224.60	80	newegg.com	GET / HTTP/1.1	
2017-07-22 02:44:35	172.16.45.172	40382		80-40382 [ACK] Seq=1 Ack=469 Win=30048	
2017-07-22	Follow TCP Stream (tcp.stream eq 1)				↑ □ ×
Stream Content					
▶ Frame 67					
▶ Ethernet					
▶ Internet					
▶ Transmis					
▶ Hypertext					
GET / HTTP/1.1					
Host: newegg.com					
Connection: keep-alive					
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8					
User-Agent: Mozilla/5.0 (Linux; Android 5.1.1; SAMSUNG SM-G530P Build/LMY47X)					
AppleWebKit/537.36 (KHTML, like Gecko) SamsungBrowser/3.3 Chrome/38.0.2125.102 Mobile					
Safari/537.36					
Accept-Encoding: gzip,deflate,sdch					
Accept-Language: en-US,en;q=0.8					
x-wap-profile: http://device.sprintpcs.com/Samsung/SM-G530P-SPRINT/QD1.rdf					
HTTP/1.1 301 Moved Permanently					
Server: AkamaiGHost					
Content-Length: 0					
Location: http://www.newegg.com/					

So which one of these three IP addresses looks the most suspicious? If you have any experience investigating suspicious network traffic, you'll find traffic to and from **172.16.45.98** looks the most suspicious of the three.

I used tcpreplay to run the pcap in a [Security Onion](#) setup running Sucirata and the EmemrgingThreats Pro ruleset. This reveals the Zyklon alerts triggered on the **172.16.45.98** traffic

RealTime Events

Escalated Events

ST	CNT	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	2017-07-22...	172.16.45.98	49158	78.47.139.102	80	6	ET POLICY Possible IP Check myexternalip.com
RT	20	2017-07-22...	172.16.45.98	49159	104.18.40.172	80	6	ET TROJAN Trojan Generic - POST To gate.php with no referer
RT	40	2017-07-22...	172.16.45.98	49159	104.18.40.172	80	6	ET TROJAN Trojan Generic - POST To gate.php with no accept headers
RT	2	2017-07-22...	172.16.45.98	49159	104.18.40.172	80	6	ETPRO TROJAN MSIL/Zyklon CnC (getkey)
RT	2	2017-07-22...	172.16.45.98	49159	104.18.40.172	80	6	ETPRO TROJAN MSIL/Zyklon CnC (key)
RT	3	2017-07-22...	172.16.45.98	49160	104.18.40.172	80	6	ETPRO TROJAN MSIL/Zyklon/Censer Plugin DL
RT	14	2017-07-22...	104.18.40.172	80	172.16.45.98	49160	6	ETPRO CURRENT_EVENTS Possible Nuclear EK Payload (URI Primer) A...

2017-07-22 TRAFFIC ANALYSIS EXERCISE - ANSWERS

You can quickly get the Windows hostname of **172.16.45.98** by filtering on NBNS traffic and that IP address in Wireshark. In the image below, you'll see MEAN-GENE-PC.

Filter: nbns and ip.addr eq 172.16.45.98						Expression...	Clear	Apply	Save
Time	Src	port	Dst	port	Info				
2017-07-22 02:45:57	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<00>				
2017-07-22 02:45:57	172.16.45.98	137	172.16.45.255	137	Registration NB WORKGROUP<00>				
2017-07-22 02:45:57	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<20>				
2017-07-22 02:45:58	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<20>				
2017-07-22 02:45:58	172.16.45.98	137	172.16.45.255	137	Registration NB WORKGROUP<00>				
2017-07-22 02:45:58	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<00>				
2017-07-22 02:45:59	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<00>				
2017-07-22 02:45:59	172.16.45.98	137	172.16.45.255	137	Registration NB WORKGROUP<00>				
2017-07-22 02:45:59	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<20>				
2017-07-22 02:46:00	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<20>				
2017-07-22 02:46:00	172.16.45.98	137	172.16.45.255	137	Registration NB WORKGROUP<00>				
2017-07-22 02:46:00	172.16.45.98	137	172.16.45.255	137	Registration NB MEAN-GENE-PC<00>				
2017-07-22 02:46:01	172.16.45.98	137	172.16.45.255	137	Name query NB WPAD<00>				

FINAL WORDS:

There's plenty of information you can dig into with this pcap, but we've answered the original objectives stated in this exercise.